

Actividad Grupal 3 - Auditoria de Software

Grupo 24

Patricio Oscar Rivero - Legajo 23039/3
Martiniano Gallo - Legajo 24296/4
Tomas Andres Castro - Legajo 23276/5
Leonardo Dos Santos - Legajo 20806/6
Mateo Andres D'Altroy - Legajo 24636/4

Durante la evaluación de calidad y la auditoría inicial del sistema se detectaron diversos problemas relacionados con permisos excesivos, registros incompletos de operaciones, errores en datos cargados, ausencia de controles automáticos y dificultades para identificar responsabilidades sobre ciertas acciones

a)

Describan brevemente el sistema desarrollado, las funcionalidades principales, los usuarios involucrados y los activos críticos del sistema (consideren datos, software, documentación, personal, infraestructura).

El sistema desarrollado consiste en una aplicación web de gestión de turnos para un gimnasio, creada bajo un enfoque ágil e iterativo en un plazo de tres meses. Su objetivo principal es permitir la administración eficiente de clases, reservas y usuarios, facilitando tanto la experiencia de los clientes como las tareas administrativas del gimnasio.

El sistema posee distintas funcionalidades centrales: el manejo de usuarios, mediante registro, inicio de sesión y cierre de sesión; la gestión de clases, que permite registrar actividades y visualizar la disponibilidad de turnos en tiempo real; y la gestión de reservas, donde los clientes pueden reservar o cancelar turnos para diferentes actividades del gimnasio. También incluimos la funcionalidad para administrar la membresía al gimnasio, poder pagarla desde el sistema y ver cuántos días quedan.

Las funcionalidades del sistema involucran distintos tipos de usuario. Por un lado, se encuentran los usuarios finales, es decir, los clientes del gimnasio que interactúan con la interfaz desde dispositivos móviles o computadoras para administrar sus reservas. Por otro lado, existe un administrador encargado de gestionar usuarios, profesores y permisos del sistema. Finalmente, el entrenador tiene la responsabilidad de registrar nuevos clientes y cargar clases o actividades.

Dentro del sistema también existen diversos activos críticos. Entre ellos se encuentran los activos de datos, entre los que se incluyen las credenciales, datos personales y financieros

de los usuarios, la información de clases y turnos, los registros estadísticos del negocio y los logs de auditoría y seguimiento. Estos datos representan un recurso esencial para el funcionamiento del gimnasio y para la imagen de la organización. Otro activo fundamental es el software, compuesto por el frontend utilizado por los clientes y el backend encargado de la lógica de negocio, la autenticación y la comunicación con la base de datos. La documentación también constituye un activo importante, ya que incluye historias de usuario, métricas de calidad, casos de prueba, informes de evaluación y la estructura de desglose del trabajo. El personal involucrado en el proyecto (un desarrollador semi-senior y dos desarrolladores junior) forma parte de los recursos críticos del sistema, al igual que la infraestructura tecnológica, integrada por el servidor de autenticación, la base de datos y los endpoints protegidos de la aplicación.

b) Analicen cómo evaluarían si el sistema cumple con los objetivos de control interno. Relacionen cada objetivo con ejemplos concretos del sistema desarrollado.

Para evaluar si el sistema de gestión del gimnasio cumple con los cuatro objetivos de la auditoría de sistemas de información, lo haríamos de la siguiente manera:

Preservar los activos: debe verificarse que el código fuente, la base de datos y la infraestructura estén protegidos frente a accesos no autorizados o modificaciones indebidas. Por ejemplo, resulta indispensable comprobar que un desarrollador junior no pueda eliminar accidentalmente el repositorio principal ni modificar directamente la base de datos de producción sin controles de auditoría. También debe garantizarse que las credenciales y datos sensibles de los usuarios estén cifrados correctamente.

Mantener la integridad de los datos: la información almacenada debe ser completa, correcta y consistente para que el gimnasio pueda operar adecuadamente. Un ejemplo concreto consiste en verificar que, cuando un usuario realiza una reserva, el sistema descuente automáticamente un cupo disponible y evite que dos clientes reserven el mismo lugar simultáneamente. De esta manera, se asegura la coherencia de los datos y se previenen errores operativos.

Lograr la efectividad (Eficacia): implica determinar si la aplicación realmente satisface las necesidades del negocio y de los usuarios. En este contexto, puede utilizarse una métrica de facilidad de uso para comprobar si los clientes logran reservar clases de forma rápida y sencilla desde distintos dispositivos.

Lograr la eficiencia: se evaluará que el sistema provea una experiencia con tiempos de espera mínimos para los usuarios. Por ejemplo, analizaremos los tiempos de respuesta del servidor para garantizar que la grilla de turnos se cargue en tiempos reducidos y sin sobrecargar el servidor.

c) Identifiquen 2 riesgos relacionados con la pérdida o modificación de datos y 2 posibles abusos computacionales y clasifíquelos.

Identificamos los siguientes riesgos relacionados con la pérdida o modificación de datos: error humano, donde un entrenador podría, por ejemplo, borrar o modificar accidentalmente los turnos de toda una semana debido a una capacitación insuficiente; y fallas de hardware o software donde, por ejemplo, un desperfecto en el almacenamiento del servidor podría corromper la base de datos y provocar la pérdida de registros de usuarios si no existen copias de seguridad adecuadas.

En cuanto a posibles abusos computacionales identificamos lo siguiente: uno de ellos es el abuso de privilegios, situación en la cual un empleado o desarrollador utiliza sus permisos legítimos para beneficiar a terceros, cómo priorizar a algunas personas sobre otras para un turno. Por otro lado hemos contemplado la posibilidad de que se agregue software malicioso al sistema (virus). Un desarrollador agrega una dependencia al proyecto durante el proceso de mantenimiento que contiene un virus el cual se infiltra en el servidor de producción. Este virus ejecuta un Ransomware para prevenir el acceso a la base de datos hasta que se pague una fianza.

d) Seleccionen al menos 4 controles internos que deberían existir en el sistema. Para cada control expliquen cómo funciona e indiquen qué problema ayudaría a prevenir o detectar.

Documentos y registros adecuados: establecer documentos y registros apropiados mediante logs automatizados de auditoría. Cada inicio de sesión, intento fallido o pago realizado debe almacenarse con información detallada, como fecha, usuario y medio de pago. Este control permite detectar ataques de fuerza bruta, garantizar la trazabilidad de operaciones y solucionar el problema de registros incompletos.

Sistema de autorizaciones: configurar en el código permisos específicos según el rol. Cada usuario debe poseer únicamente los permisos necesarios para realizar sus tareas. Así, un cliente solo podrá reservar clases para sí mismo, mientras que un entrenador administrará actividades y un administrador gestionará usuarios y estadísticas. Este control previene los accesos de usuarios con permisos excesivos y facilita la identificación de responsabilidades sobre determinadas acciones.

Separación de obligaciones: los desarrolladores junior pueden escribir código, pero únicamente el desarrollador semi-senior debe tener autorización para desplegar cambios en producción. Esto evita que un Junior introduzca vulnerabilidades críticas sin supervisión (o modificaciones no autorizadas).

Comparación periódica de activos con registros: implementar validaciones automáticas de consistencia que comparen periódicamente la cantidad de reservas con los cupos disponibles. Estas rutinas permiten detectar errores de datos y compensar la ausencia de controles automáticos.

e) Redacten al menos 2 hallazgos completos incluyendo: situación observada, problema detectado e impacto posible.

Hallazgo 1: Usuarios con permisos excesivos

Usuarios normales pueden acceder a endpoints no protegidos del backend y modificar clases del gimnasio. Esto representa un riesgo grave, ya que un cliente malintencionado podría cancelar clases de otros usuarios o eliminar cronogramas, provocando pérdidas de clientes y daños a la reputación del gimnasio.

Hallazgo 2: el sistema de reservas permite registrar reservas incluso cuando el cupo máximo de una clase ya había sido alcanzado

Esto se debe a la ausencia de validaciones adecuadas sobre la disponibilidad de las clases. Como consecuencia, se podría desbordar la capacidad de una actividad, ocasionando que el gimnasio colapse físicamente por exceso de personas, generando quejas y devoluciones de dinero.

f) Seleccionen una decisión de planificación de la Actividad grupal 1 y una métrica de calidad de la Actividad grupal 2 y expliquen cómo se relacionan con los problemas encontrados durante la auditoría.

Decisión de Planificación (Actividad 1): El grupo decidió dividir la jornada del único desarrollador Semi-Senior en paralelo (4 horas al frontend y 4 horas al backend), dejando a un Junior dedicado full-time a realizar el backend y la lógica de seguridad con supervisión parcial.

Métrica de Calidad (Actividad 2): "Tasa de bloqueos de accesos no autorizados" (Evaluación de Seguridad)

Relación con los problemas: al delegar la infraestructura y seguridad casi por completo a un desarrollador Junior con poca experiencia, el código del backend quedó severamente vulnerable. Esta mala decisión de planificación es la causa directa de los problemas detectados en la auditoría, ya que el Junior no cuenta con la experiencia necesaria para implementar correctamente el sistema de autorizaciones ni los logs. En consecuencia, la métrica de Seguridad en la evaluación de calidad tuvo un resultado deficiente, impactando directamente en la protección de los datos.